

Hallazgos de análisis externo — ERSO 2026-002

- Hallazgos de análisis externo — ERSO 2026-002
 - Suite criptográfica y formatos de credencial: SD-JWT VC y mdoc
 - 1. Resumen
 - 2. Proyectos citados en este informe
 - 3. Hallazgos
 - 4. Aplicación a los criterios de aceptación de la ERSO 002
 - 5. Diferencias de diseño frente a nuestro proyecto
 - 6. Qué aprender y qué hacer con esto
 - 7. Límites de este informe

Hallazgos de análisis externo — ERSO 2026-002

Suite criptográfica y formatos de credencial: SD-JWT VC y mdoc

Proyecto propio	Identidad Digital Soberana SSI (/home/geovani/Descargas/generic/bitacora/new_project)
Fecha del análisis	2 de octubre de 2026
Carpetas analizadas	/home/geovani/Workspace/Wallet/Wallet , .../Verifier , .../Issuer , .../Trust , .../librerias
Versión del informe	Actualizado el 2 de octubre de 2026: se añaden los hallazgos de la carpeta librerias y el análisis a fondo del gestor de listas de confianza
Cobertura de esta ERSO	Muy alta (emisor, cartera, verificador, bibliotecas y RFC)
Método	Lectura de código y documentación; no se compiló ni se ejecutó ninguno de los proyectos externos

1. Resumen

La ERSO 002 exige emitir y recibir `dc+sd-jwt` y `mso_mdoc` con protocolos estándar (OpenID4VCI/OpenID4VP), un perfil declarado que coincida con lo usado, ningún protocolo propio y firmas separadas. Los proyectos externos traen implementaciones completas de emisor (`Issuer/eudi-srv-pid-issuer` , `Issuer/eudi-srv-web-issuing-eudiw-py`), verificador (`Verifier/eudi-srv-verifier-endpoint`) y cartera (`Wallet/eudi-app-android-wallet-ui` , `Wallet/av-app-android-wallet-ui`). Se ven con claridad las **diferencias de perfil** que nuestro informe ya había declarado: cifrado JWE obligatorio, DPoP, identificación del emisor por `x5c` y presentación de mdoc. **Complemento (carpeta Librerías)**: las bibliotecas son el código de donde salen los emisores, verificadores y carteras ya analizados. Aportan tres hallazgos centrales: el soporte de **DID como método de identificación del emisor** en la biblioteca de SD-JWT (marcado como obsoleto), el soporte de **DID como identificador del verificador** en OpenID4VP, y los **métodos alternativos de clave del emisor** (metadatos, `x5c` , DID).

2. Proyectos citados en este informe

Carpeta	Proyecto	Qué es
Issuer	<code>eudi-srv-pid-issuer</code>	Emisor de credenciales (Kotlin/Spring)
Issuer	<code>eudi-srv-web-issuing-eudiw-py</code>	Emisor web con revocación (Python/Flask)
Wallet	<code>eudi-app-android-wallet-ui</code>	App Android de la cartera EUDI (referencia)
Wallet	<code>av-app-android-wallet-ui</code>	App Android de verificación de edad (versión derivada de la anterior); incluye el módulo <code>vdr-extension-logic</code>
Verifier	<code>eudi-srv-verifier-endpoint</code>	Backend verificador (Kotlin/Spring)
Verifier	<code>eudi-wallet-rfcs</code>	Especificaciones EWC (RFC 001 a 013)
Verifier	<code>eudi-srv-statuslist-py</code>	Servidor de listas de estado / revocación (Python)
librerias	<code>eudi-lib-jvm-sdjwt-kt</code>	Biblioteca de SD-JWT y SD-JWT VC (verificación, métodos de clave del emisor)
librerias	<code>eudi-lib-jvm-openid4vci-kt</code>	Biblioteca de OpenID4VCI 1.0 (emisión, DPoP, attestation, diferida, notificación)
librerias	<code>eudi-lib-jvm-openid4vp-kt</code>	Biblioteca de OpenID4VP (autenticación del verificador, cifrado de respuesta, DID)
librerias	<code>eudi-lib-jvm-presentation-exchange-kt</code>	Biblioteca de Presentation Exchange v2
librerias	<code>eudi-lib-android-wallet-document-manager</code>	Gestor de documentos de la cartera (estados, políticas de credencial, claves)
librerias	<code>eudi-web-recruitment-service-demo</code>	Demostración de portal de reclutamiento que usa emisor y verificador EUDI
librerias	<code>eudi-lib-kmp-statium</code>	Biblioteca de listas de estado de tokens (draft 12)

3. Hallazgos

La columna *Criterio* indica a qué criterio de aceptación de la ERSO se aplica el hallazgo (el detalle está en la sección 4).

#	Proyecto (carpeta/proyecto)	Archivo o lugar	Qué se encontró	Relación con proyecto
1	Issuer/eudi-srv-pid-issuer	src/main/resources/application.properties	Perfil declarado: pid.mso_mdoc.enabled , pid.sd_jwt_vc.enabled , proofs.supportedSigningAlgorithms=ES256 , digests.hashAlgorithm=sha-256 , vigencia P31D , lotes de 20 credenciales.	Equivalencia a Credential (ES256, sha-256)
2	Issuer/eudi-srv-pid-issuer	.../domain/SdJwtVcProfile.kt, MsoMdocProfile.kt, CredentialConfiguration.kt	El perfil de cada formato está en clases separadas.	Nuestro perfil solo archivo (Profiles.kt) comprueba registro de
3	Issuer/eudi-srv-pid-issuer Issuer/eudi-srv-web-issuing-eudiwpy	.../port/input/GetCredentialIssuerMetadata.kt; app/signed_metadata.py	Metadatos del emisor, incluidos metadatos firmados (GenerateSignedMetadataWithNimbus.kt).	Nosotros por metadatos
4	Issuer/eudi-srv-web-issuing-eudiwpy	app/route_oidc.py (/credential 886, /nonce 1082, /notification 1041, /deferred_credential 1123)	Endpoints de credencial, nonce, notificación y credencial diferida.	Nuestro info diferido y no como no im
5	Issuer/eudi-srv-pid-issuer	.../port/input/CreateCredentialsOffer.kt; I-py app/preauthorization.py y api_docs/pre-authorized.md	Ofertas de credencial con código pre-autorizado.	Equivalencia a ofertas con
6	Issuer/eudi-srv-pid-issuer	application.properties (credentialRequestEncryption.required=true , credentialResponseEncryption.required=true) y .../adapter/out/jose/DecryptRequestWithNimbus.kt	Cifrado JWE (ECDH-ES, A128GCM/A256GCM) de solicitud y respuesta, obligatorio .	Nosotros no la diferenciamos declaramos
7	Issuer/eudi-srv-pid-issuer	.../adapter/input/web/security/DPOP.kt; issuer.dpop.nonce.enabled=true``	DPoP con nonce (token ligado a una clave).	Nosotros no implementa
8	Issuer/eudi-srv-pid-issuer	.../adapter/out/IssuerSigningKey.kt (línea ~41)	La clave del emisor exige cadena x5c .	Nosotros id emisor con Un verificac estándar no nuestras cr adaptación
9	Wallet/eudi-app-android-wallet-ui Wallet/av-app-android-wallet-ui	core-logic/src/dev/.../WalletCoreConfigImpl.kt (withFormats)	eudi-app-android-wallet-ui: Format.MsoMdoc.ES256 y Format.SdJwtVc.ES256. av-app-android-wallet-ui: SOLO MsoMdoc.ES256.	Mismo perf (ES256).
10	Wallet/eudi-app-android-wallet-ui Wallet/av-app-android-wallet-ui	core-logic/.../controller/WalletCoreDocumentsController.kt (líneas ~230, 305, 568, 663)	OpenId4VciManager , issueDocumentByOffer , resolveDocumentOffer .	Equivalente Credential
11	Wallet/eudi-app-android-wallet-ui Wallet/av-app-android-wallet-ui	.../WalletCoreConfigImpl.kt (vciConfig)	AttestationBased , DPopConfig.Default , ParUsage.NEVER ; av-app-android-wallet-ui apunta al emisor de pruebas https://test.issuer.dev.ageverification.dev .	Un tercero o se podría p interoperab 1).
12	Verifier/eudi-srv-verifier-endpoint	src/main/resources/application.properties	sdJwtAlgorithms=ES256 , kbJwtAlgorithms=ES256 , msoMdoc.enabled=true , defaultHttpResponseMode=DirectPostJwt .	Perfil declar verificador.
13	Verifier/eudi-srv-verifier-endpoint	.../adapter/input/web/VerifierApi.kt y WalletApi.kt	Inventario de endpoints: /ui/presentations... , /wallet/request.jwt/... , /wallet/direct_post/{requestId} , /wallet/public-keys.json .	Base para c inventario c como nuest
14	Verifier/eudi-srv-verifier-endpoint	.../adapter/out/jose/VerifyEncryptedResponseWithNimbus.kt; CreateJarNimbus.kt	Respuesta de la cartera cifrada (JWE) y solicitud firmada (JAR).	Ambas cos de nuestro
15	Verifier/eudi-srv-verifier-endpoint	.../adapter/out/mso/DeviceResponseValidator.kt, DocumentValidator.kt	Validación de la presentación de mdoc (DeviceResponse).	Es lo que no declara "no implementa
16	Verifier/eudi-srv-verifier-endpoint	.../port/input/PostWalletResponse.kt (línea ~466)	ensure(presentation.channel.requestId.value == responseObject.state) { IncorrectState } .	Equivalencia a comprobac
17	Verifier/eudi-srv-verifier-endpoint	.../domain/Presentation.kt (líneas ~213 a 320)	Estados Requested , RequestObjectRetrieved , Submitted , TimedOut .	Nuestro ver guarda el e memoria.
18	Verifier/eudi-wallet-rfcs	ewc-supported-formats.csv; ewc-supported-cryptographic-suites.csv; ewc-rfc001 y ewc-rfc002	Formatos permitidos (dc+sd-jwt , vc+sd-jwt , mso_mdoc) y suites (ES256, P-256).	Referencia de interope
19	Issuer/eudi-srv-web-issuing-eudiwpy	app/route_formatter.py (/cbor , /sd-jwt)	Formateadores internos junto a los endpoints estándar.	Para un inv que disting de lo intern
20	Verifier/eudi-srv-statuslist-py	app/status_list_endpoints.py (/take , /get , /set)	Servicio de listas de estado para revocación.	Nosotros no implementa revocación.

#	Proyecto (carpeta/proyecto)	Archivo o lugar	Qué se encontró	Relación c proyecto
21	librerias/eudi-lib-jvm-sdjwt-kt	src/main/kotlin/.../sdjwt/vc/NimbusSdJwtVcVerifierFactory.kt (líneas ~56 a 80) y SdJwtVcVerifier.kt (línea ~113)	El verificador de SD-JWT VC admite los métodos de clave del emisor UsingIssuerMetadata, UsingX5c, UsingDID , UsingX5c0rIssuerMetadata y Custom. El DID se resuelve con una función inyectable LookupPublicKeysFromDIDDocument.	Respalda n (clave del e = DID URL) método pre biblioteca d
22	librerias/eudi-lib-jvm-sdjwt-kt	.../sdjwt/vc/SdJwtVcVerifierFactory.kt (línea ~50)	LookupPublicKeysFromDIDDocument está marcada obsoleta ("Deprecated in SD-JWT-VC draft 11 to be removed in future version").	Riesgo para diseño: la ic del emisor desaparece especifica vigilar la ve adoptada.
23	librerias/eudi-lib-jvm-sdjwt-kt	.../NimbusSdJwtVcVerifierFactory.kt (líneas ~190 a 205)	Si no hay función de búsqueda configurada se rechaza con UnsupportedVerificationMethod("did"); si la resolución falla, DIDLookupFailure.	Equivale a i RESOLUTION, códigos de tipados.
24	librerias/eudi-lib-jvm-sdjwt-kt	.../SdJwtVcVerifierFactory.kt (X509CertificateTrust.usingVct)	La confianza en una cadena x5c se decide por tipo de credencial (vct).	Confianza c del tipo; nu autoriza po verificación
25	librerias/eudi-lib-jvm-sdjwt-kt	src/test/kotlin/.../sdjwt/KeyBindingTest.kt	Pruebas del enlace de clave del titular (key binding).	Referencia para la prue (KB-JWT).
26	librerias/eudi-lib-jvm-openid4vci-kt	src/main/kotlin/.../openid4vci/ (Issuer.kt, Issuance.kt, DPoP.kt, DeferredIssuer.kt, NotifyIssuer.kt, RefreshAccessToken.kt, CredentialOffer.kt, AuthorizeIssuance.kt)	La biblioteca de OpenID4VCI cubre oferta, autorización, token, DPoP, nonce, credencial, diferida, notificación y renovación de token. El README documenta el flujo pre-autorizado y la consulta de credenciales diferidas.	Es la imple la que sale comportam nuestro info como no im
27	librerias/eudi-lib-jvm-openid4vci-kt	.../openid4vci/internal/Proof.kt	Tipos de prueba de posesión: Jwt y Attestation.	Nuestro em solo prueba
28	librerias/eudi-lib-jvm-openid4vci-kt	.../openid4vci/internal/IssuanceEncryption.kt	Cifrado de solicitud y respuesta de credencial.	Confirma la perfil docur (nosotros n
29	librerias/eudi-lib-jvm-openid4vp-kt	src/main/kotlin/.../openid4vp/internal/request/RequestAuthenticator.kt (líneas ~240 a 250)	Prefijos de client_id admitidos, entre ellos DecentralizedIdentifier (el verificador se identifica con un DID) y VerifierAttestation; el prefijo DID exige solicitud firmada .	Aquí el DID identificar a verificado emisor.
30	librerias/eudi-lib-jvm-openid4vp-kt	.../openid4vp/internal/response/ResponseEncryption.kt	Cifrado de la respuesta de la cartera (ECDH-ES o RSA).	Elemento fi nuestro alci
31	librerias/eudi-lib-jvm-presentation-exchange-kt	eudi-lib-jvm-presentation-exchange-kt (README, MatcherTest.kt)	Implementa Presentation Exchange v2 (definiciones y emparejamiento).	Alternativa DCQL; nues usa DCQL.
32	librerias/eudi-lib-android-wallet-document-manager	document-manager/.../credential/ (SdJwtVcCredentialCertifier, MsoMdocCredentialCertifier, ProofOfPossessionSigner)	Componentes que completan la credencial recibida y firman la prueba de posesión.	Equivalente Credential (guardar lo firmar la pr
33	librerias/eudi-web-recruitment-service-demo	eudi-web-recruitment-service-demo/README.md	Arquitectura con puertos y adaptadores (IVerifierPort, IIssuerPort, EudiVerifierAdapter, EudiIssuerAdapter), PostgreSQL y consulta del verificador cada segundo.	Modelo de c servicio de integra emi verificador; pruebas coi
34	librerias/eudi-lib-kmp-statium	eudi-lib-kmp-statium (README)	Implementa Token Status List draft 12 para comprobar si un token está vigente, revocado o suspendido.	Base para c revocación; parte de nu criterios.

4. Aplicación a los criterios de aceptación de la ERSo 002

Para cada criterio: lo que exige el PDF de la ERSo, dónde está nuestra evidencia y qué hallazgos externos se le aplican.

Criterio 1. La emisión y la recepción funcionan en dc+sd-jwt y mso_mdoc conforme al perfil adoptado.

Evidencia que pide la ERSo	Pruebas cruzadas con OpenID4VCI 1.0 y OpenID4VP 1.0.
Nuestra evidencia	INFORME-FINAL-ERSo-2026-002 §17

Hallazgos aplicables	#3 (Issuer/eudi-srv-pid-issuer, Issuer/eudi-srv-web-issuing-eudiw-py); #4 (Issuer/eudi-srv-web-issuing-eudiw-py); #5 (Issuer/eudi-srv-pid-issuer); #6 (Issuer/eudi-srv-pid-issuer); #7 (Issuer/eudi-srv-pid-issuer); #10 (Wallet/eudi-app-android-wallet-ui, Wallet/av-app-android-wallet-ui); #11 (Wallet/eudi-app-android-wallet-ui, Wallet/av-app-android-wallet-ui); #14 (Verifier/eudi-srv-verifier-endpoint); #15 (Verifier/eudi-srv-verifier-endpoint); #16 (Verifier/eudi-srv-verifier-endpoint); #17 (Verifier/eudi-srv-verifier-endpoint); #23 (librerias/eudi-lib-jvm-sdjwt-kt); #26 (librerias/eudi-lib-jvm-openid4vci-kt); #27 (librerias/eudi-lib-jvm-openid4vci-kt); #28 (librerias/eudi-lib-jvm-openid4vci-kt); #29 (librerias/eudi-lib-jvm-openid4vp-kt); #30 (librerias/eudi-lib-jvm-openid4vp-kt); #31 (librerias/eudi-lib-jvm-presentation-exchange-kt); #32 (librerias/eudi-lib-android-wallet-document-manager); #33 (librerias/eudi-web-recruitment-service-demo)
Qué aporta el análisis	Hay implementaciones completas de terceros (emisor, verificador y cartera) y un emisor de pruebas público en la app de verificación de edad. Permiten cerrar la brecha de interoperabilidad que nuestro informe declara. Las bibliotecas permiten construir pruebas cruzadas con terceros usando su mismo código de referencia.

Criterio 2. Los algoritmos y formatos declarados coinciden con los efectivamente usados.

Evidencia que pide la ERSo	Documento de perfil por formato y registro de ejecución.
Nuestra evidencia	INFORME-FINAL-ERSo-2026-002 §18
Hallazgos aplicables	#1 (Issuer/eudi-srv-pid-issuer); #2 (Issuer/eudi-srv-pid-issuer); #3 (Issuer/eudi-srv-pid-issuer, Issuer/eudi-srv-web-issuing-eudiw-py); #6 (Issuer/eudi-srv-pid-issuer); #9 (Wallet/eudi-app-android-wallet-ui, Wallet/av-app-android-wallet-ui); #12 (Verifier/eudi-srv-verifier-endpoint); #18 (Verifier/eudi-wallet-rfcs); #24 (librerias/eudi-lib-jvm-sdjwt-kt); #27 (librerias/eudi-lib-jvm-openid4vci-kt); #28 (librerias/eudi-lib-jvm-openid4vci-kt)
Qué aporta el análisis	Los proyectos externos declaran el perfil en propiedades de configuración; no se encontró un registro de ejecución que lo contraste. Es un aporte propio.

Criterio 3. No existe ningún protocolo propio paralelo a OpenID4VCI ni OpenID4VP.

Evidencia que pide la ERSo	Inventario de endpoints y revisión de código de integración.
Nuestra evidencia	INFORME-FINAL-ERSo-2026-002 §19
Hallazgos aplicables	#4 (Issuer/eudi-srv-web-issuing-eudiw-py); #7 (Issuer/eudi-srv-pid-issuer); #13 (Verifier/eudi-srv-verifier-endpoint); #19 (Issuer/eudi-srv-web-issuing-eudiw-py); #23 (librerias/eudi-lib-jvm-sdjwt-kt); #29 (librerias/eudi-lib-jvm-openid4vp-kt)
Qué aporta el análisis	Las rutas de los servidores externos sirven de modelo para construir un inventario con su norma, distinguiendo lo estándar de lo interno.

Criterio 4. La firma del emisor está separada de la prueba del titular.

Evidencia que pide la ERSo	Matriz de claves por rol y pruebas de verificación independientes.
Nuestra evidencia	INFORME-FINAL-ERSo-2026-002 §20
Hallazgos aplicables	#8 (Issuer/eudi-srv-pid-issuer); #21 (librerias/eudi-lib-jvm-sdjwt-kt); #22 (librerias/eudi-lib-jvm-sdjwt-kt); #25 (librerias/eudi-lib-jvm-sdjwt-kt); #32 (librerias/eudi-lib-android-wallet-document-manager)
Qué aporta el análisis	El emisor externo exige certificado x5c para su clave y valida aparte la prueba del titular; confirma la separación, con identificación del emisor distinta de la nuestra. La biblioteca de SD-JWT contempla el DID como método de clave del emisor, pero lo marca obsoleto.

5. Diferencias de diseño frente a nuestro proyecto

Tema	Proyectos externos	Nuestro proyecto
Identificación del emisor	x5c (certificados)	kid = DID URL resuelta en el registro
Cifrado de solicitud y respuesta	JWE obligatorio	No hay
Token del emisor	DPoP	Token sin DPoP
Presentación de mdoc	Implementada (Verifier/eudi-srv-verifier-endpoint)	No implementada
Metadatos del emisor	Pueden ir firmados	Sin firma
Revocación	Listas de estado	No implementada
Estado de emisor y verificador	Persistente	En memoria
Método de clave del emisor en la biblioteca de referencia	metadatos, x5c o DID (este último obsoleto)	DID

6. Qué aprender y qué hacer con esto

- Hallazgo más útil: av-app-android-wallet-ui ofrece un emisor de pruebas real (test.issuer.dev.ageverification.dev); permitiría cerrar la brecha de "pruebas cruzadas con terceros" del criterio 1.
- Para el criterio 3: VerifierApi.kt y WalletApi.kt sirven de modelo para un inventario de endpoints con su norma.
- Para el criterio 2: los dos proyectos declaran el perfil en propiedades; el nuestro añade un registro de ejecución que lo contrasta, algo que no se encontró en ellos.
- Decidir si se adopta x5c como alternativa al DID para interoperar con verificadores EUDI.
- Riesgo a registrar: la especificación de SD-JWT VC deja de contemplar el DID como método de clave del emisor (obsoleto desde el borrador 11). Si se quiere interoperar con carteras EUDI, conviene ofrecer también metadatos del emisor o x5c.

- Para la defensa del criterio 4: `NimbusSdJwtVcVerifierFactory` muestra cómo una biblioteca de referencia separa la búsqueda de la clave del emisor de la verificación de la prueba del titular.

7. Límites de este informe

- Todo proviene de **lectura de código**; el comportamiento real no se verificó ejecutando.
- Se citan archivos y, cuando se anotó, números de línea (con ~ si son aproximados); las versiones de los proyectos son las que había en disco el 2 de octubre de 2026.
- "No encontré" significa que las búsquedas realizadas no lo hallaron, no que no exista en ninguna parte del código.
- Los proyectos de referencia EUDI se declaran a sí mismos como versiones de desarrollo no aptas para producción.